



ACTIVIDAD 02

Análisis de servicios de seguridad (X.800 y RFC 4949)

CNO V

Seguridad Informática

José Vicente Rodríguez Rivera

179954

Introducción

El presente trabajo analiza distintos escenarios reales de seguridad informática utilizando dos marcos de referencia ampliamente aceptados: el RFC 4949 y la recomendación ITU-T X.800. A partir de estos documentos, se busca identificar y describir de manera técnica los incidentes de seguridad, así como los servicios afectados, los tipos de amenazas involucradas y las posibles medidas de control.

El RFC 4949, emitido por la IETF, reúne la terminología fundamental empleada en el ámbito de la seguridad de la información y las redes, lo que permite describir los escenarios de forma clara y precisa, evitando interpretaciones ambiguas. Por su parte, la recomendación ITU-T X.800 establece un marco conceptual que define los servicios de seguridad necesarios para proteger los sistemas de comunicación, como la autenticación, el control de acceso, la confidencialidad, la integridad, el no repudio y la disponibilidad.

El uso conjunto de ambos marcos permite realizar un análisis estructurado de los incidentes, relacionando la terminología del RFC 4949 con los servicios de seguridad definidos en X.800. De esta manera, se facilita la comprensión del impacto de cada escenario y se refuerza la importancia de aplicar estos estándares en el análisis y documentación de incidentes de seguridad informática en contextos reales.

Escenario 01.

En múltiples incidentes atribuidos al grupo LockBit, organizaciones públicas y privadas han sufrido el cifrado masivo de servidores tras un acceso inicial no autorizado. Antes de ejecutar el ransomware, los atacantes exfiltraron información sensible y posteriormente amenazaron con su publicación, evidenciando un compromiso simultáneo de la confidencialidad, la integridad y la disponibilidad. Desde el enfoque del RFC 4949, el incidente se clasifica como un multi-stage attack con data breach y availability attack, donde la indisponibilidad del sistema es solo una fase final del daño. La ausencia de respaldos inmutables y de detección temprana permitió que el impacto fuera total

Elemento	Respuesta
Servicios X.800 comprometidos	Control de acceso, confidencialidad de datos, integridad, disponibilidad, autenticación
Definición(es) aplicable(s) RFC 4949	Multi-stage attack: Ataque compuesto por múltiples fases secuenciales, como acceso inicial, exfiltración de información y ejecución de ransomware. Data breach: Incidente de seguridad en el cual información sensible, protegida o confidencial es accedida o divulgada sin autorización. Availability attack: Ataque cuyo objetivo es degradar, interrumpir o impedir el acceso legítimo a sistemas o servicios, afectando su disponibilidad.
Tipo de amenaza	Externo (Acceso inicial no autorizado)
Vector de ataque	Compromiso inicial de credenciales o explotación de vulnerabilidades, despliegue de ransomware.

Impacto técnico / operativo	Cifrado masivo de servidores, pérdida de acceso a sistemas críticos, interrupción de operaciones y riesgo de divulgación de información sensible.
Medida de control recomendada	Implementación de respaldos inmutables, segmentación de red, monitoreo y detección temprana de actividades anómalas, y fortalecimiento de controles de acceso.

Escenario 02.

En diversos casos documentados, bases de datos completas quedaron accesibles públicamente debido a errores de configuración en servicios de almacenamiento en la nube. No existió una explotación técnica sofisticada, sino una falla en el control de acceso, lo que derivó directamente en la pérdida de confidencialidad de los datos. El RFC 4949 describe este tipo de incidentes como misconfiguration y exposure, subrayando que la amenaza no siempre implica malware o intrusión activa. El impacto suele ser legal y reputacional, aun cuando no se pueda demostrar acceso malicioso.

Elemento	Respuesta
Servicios X.800 comprometidos	Confidencialidad de datos, control de acceso
Definición(es) aplicable(s) RFC 4949	Misconfiguration: Condición en la que un sistema o servicio presenta configuraciones incorrectas o inseguras. Exposure: Estado en el cual información o recursos quedan accesibles a entidades no autorizadas Malware: Software malicioso Active intrusion: Evento de seguridad donde un intruso gana acceso a un sistema sin tener autorización para hacerlo
Tipo de amenaza	Interna (Error de configuración en controles de acceso)
Vector de ataque	Configuración incorrecta de controles de acceso en servicios de almacenamiento en la nube.
Impacto técnico / operativo	Pérdida de confidencialidad de datos sensibles, posibles sanciones legales, mala reputación y pérdida de confianza de clientes
Medida de control recomendada	Implementación de políticas estrictas de control de acceso, revisiones periódicas de configuración

Escenario 03.

Un proveedor legítimo de software fue comprometido y distribuyó una actualización que incluía código malicioso, afectando a cientos de organizaciones que confiaban en él. Este escenario refleja una violación grave de la integridad de los sistemas y, en muchos casos, de la confidencialidad, al

permitir accesos no autorizados posteriores. El RFC 4949 lo identifica como supply chain attack, destacando el abuso de relaciones de confianza. El daño es particularmente crítico porque rompe el supuesto de legitimidad del software firmado.

Elemento	Respuesta
Servicios X.800 comprometidos	Autenticación, confidencialidad de datos, no repudio, integridad, control de acceso
Definición(es) aplicable(s) RFC 4949	Supply chain attack: Tipo de ataque en el que un adversario compromete un proveedor legítimo o un componente confiable del proceso de desarrollo, distribución o actualización de software, con el fin de introducir código malicioso que será distribuido a múltiples víctimas que confían en dicha fuente.
Tipo de amenaza	Externa (Abuso de confianza)
Vector de ataque	Actualización con código malicioso o percibido como legítimo
Impacto técnico / operativo	Integridad de los sistemas afectados, posible acceso no autorizado posterior, pérdida de confidencialidad de la información
Medida de control recomendada	Verificación estricta de la integridad de actualizaciones, controles de seguridad en la cadena de suministro de software

Escenario 04.

Mediante campañas de phishing, atacantes obtuvieron credenciales válidas y accedieron a sistemas corporativos durante meses sin levantar alertas. Aunque la autenticación funcionó técnicamente, el servicio de autenticación fue comprometido al basarse en credenciales robadas, afectando también el control de acceso. Según el RFC 4949, se trata de un credential compromise con authentication failure conceptual, no técnica. La falta de MFA y de monitoreo de comportamiento facilitó la persistencia del atacante

Elemento	Respuesta
Servicios X.800 comprometidos	Control de acceso, autenticación
Definición(es) aplicable(s) RFC 4949	credential compromiso: Credenciales de autenticación válidas son obtenidas por una entidad no autorizada authentication failure: Fallo en el proceso de autenticación que ocurre cuando el sistema acepta credenciales válidas sin detectar que han sido comprometidas
Tipo de amenaza	Externa (Credenciales válidas e ingeniería social)
Vector de ataque	Campañas de phishing dirigidas a usuarios corporativos

Impacto técnico / operativo	Acceso no autorizado prolongado a sistemas corporativos, persistencia del atacante, posible escalamiento de privilegios
Medida de control recomendada	MFA robusto, monitoreo de comportamiento de usuarios, detección de accesos anómalos y revisión periódica de privilegios.

Escenario 05.

En ataques de ransomware avanzados, los atacantes eliminaron o cifraron los respaldos antes de afectar los sistemas productivos. Este hecho compromete directamente la disponibilidad y la integridad de la información, al impedir la recuperación. El RFC 4949 clasifica este comportamiento como data destruction y availability attack, evidenciando intención deliberada de maximizar el daño. La inexistencia de respaldos offline o inmutables convierte el incidente en catastrófico.

Elemento	Respuesta
Servicios X.800 comprometidos	Disponibilidad, integridad de datos
Definición(es) aplicable(s) RFC 4949	Data destruction: Acción mediante la cual datos son eliminados, alterados o inutilizados de forma intencional Availability attack: Ataque dirigido a degradar o impedir el acceso a sistemas, servicios o información
Tipo de amenaza	Externa (Maximizar el impacto operativo del incidente)
Vector de ataque	Ejecución de ransomware con privilegios suficientes para eliminar o cifrar respaldos antes de afectar los sistemas productivos.
Impacto técnico / operativo	Pérdida de capacidad de recuperación ante desastres, interrupción prolongada de operaciones críticas
Medida de control recomendada	Implementación de respaldos offline e inmutables, segregación de privilegios administrativos

Escenario 06.

Un empleado con acceso legítimo extrajo bases de datos completas y las vendió a terceros, sin explotar vulnerabilidades técnicas. El servicio afectado fue principalmente la confidencialidad, junto con fallas en el control de acceso por exceso de privilegios. El RFC 4949 define este escenario como insider threat, destacando que el riesgo interno puede ser tan grave como el externo. La carencia de monitoreo y de políticas de mínimo privilegio fue determinante.

Elemento	Respuesta
Servicios X.800 comprometidos	Confidencialidad, control de acceso
Definición(es) aplicable(s) RFC 4949	insider threat: Amenaza originada por una persona con acceso legítimo a los sistemas o información de una organización
Tipo de amenaza	Interno (empleado con acceso legítimo)
Vector de ataque	Uso indebido de credenciales válidas y privilegios excesivos
Impacto técnico / operativo	Pérdida de confidencialidad de información sensible, posibles sanciones legales, afectación reputacional
Medida de control recomendada	Políticas de mínimo privilegio, monitoreo continuo de actividades de usuarios privilegiados,

Escenario 07.

Tras un ataque, los registros del sistema quedaron cifrados o alterados, impidiendo reconstruir la secuencia de eventos. Esto compromete la integridad de los datos y el no repudio, ya que no es posible demostrar qué ocurrió ni quién fue responsable. Desde el RFC 4949, se trata de una violación de evidentiary integrity y del audit trail. El impacto no solo es técnico, sino también probatorio y legal.

Elemento	Respuesta
Servicios X.800 comprometidos	No repudio, integridad
Definición(es) aplicable(s) RFC 4949	evidentiary integrity: Garantiza que la evidencia digital se mantiene completa, auténtica y no alterada audit Trail: Registro cronológico de eventos y actividades del sistema que permite reconstruir acciones realizadas
Tipo de amenaza	Externa (Ocultar actividades maliciosas)
Vector de ataque	Alteración o cifrado deliberado de registros del sistema y archivos de auditoría
Impacto técnico / operativo	Imposibilidad de reconstruir la secuencia de eventos, pérdida de trazabilidad, afectación al no repudio
Medida de control recomendada	Protección de registros mediante mecanismos de integridad, almacenamiento seguro e inmutable de logs

Escenario 08.

Una actualización mal ejecutada provocó la caída simultánea de múltiples servicios críticos a nivel global. Aunque no existió un atacante, el servicio de disponibilidad fue gravemente afectado. El RFC 4949 contempla estos eventos como operational failure, recordando que la seguridad también se ve afectada por errores internos. La falta de pruebas previas y planes de reversión amplificó el impacto

Elemento	Respuesta
Servicios X.800 comprometidos	Disponibilidad
Definición(es) aplicable(s) RFC 4949	operational failure: Evento en el que un sistema o servicio falla debido a errores internos, fallas de operación o procesos inadecuados, sin la intervención de un atacante
Tipo de amenaza	Interna (Fallas operativas)
Vector de ataque	Actualización mal ejecutada
Impacto técnico / operativo	Interrupción simultánea de servicios críticos, pérdida de disponibilidad a gran escala, afectación a operaciones globales
Medida de control recomendada	Procesos formales de gestión de cambios, pruebas previas en entornos controlados, planes de reversión

Escenario 09.

Atacantes replicaron sitios y correos oficiales para engañar a ciudadanos y obtener información sensible. Este escenario afecta la autenticación, al suplantar identidades legítimas, y la confidencialidad de los datos recolectados. El RFC 4949 lo clasifica como masquerade y phishing, subrayando el componente de ingeniería social. La ausencia de mecanismos de autenticación del dominio y de concientización facilitó el éxito del ataque.

Elemento	Respuesta
Servicios X.800 comprometidos	Autenticación, confidencialidad
Definición(es) aplicable(s) RFC 4949	Masquerade: Tipo de ataque en el que una entidad se hace pasar por otra entidad legítima con el fin de obtener acceso no autorizado o información sensible. Phishing: Técnica de ingeniería social mediante la cual un atacante engaña a las víctimas para que revelen información confidencial, haciéndose pasar por una entidad confiable a través de medios electrónicos.
Tipo de amenaza	Externa (Ingeniería social)
Vector de ataque	Sitios y correos oficiales replicados

Impacto técnico / operativo	Compromiso de credenciales y datos personales, afectación a la autenticidad de comunicaciones oficiales
Medida de control recomendada	Mecanismos de autenticación de dominio, concientización

Escenario 10.

En algunos incidentes, tras exfiltrar información, los atacantes ejecutaron acciones destructivas para borrar sistemas completos y eliminar rastros. Se produce un compromiso total de la confidencialidad, la integridad y la disponibilidad, configurando uno de los peores escenarios posibles. El RFC 4949 describe este patrón como destructive attack, donde el objetivo no es solo el lucro, sino el daño irreversible. La detección tardía impidió cualquier contención efectiva.

Elemento	Respuesta
Servicios X.800 comprometidos	Confidencialidad, disponibilidad, integridad
Definición(es) aplicable(s) RFC 4949	destructive attack: Un adversario ejecuta acciones deliberadas para eliminar, corromper o inutilizar sistemas y datos
Tipo de amenaza	Externa (Causar daño irreversible)
Vector de ataque	Acceso no autorizado prolongado que permite la exfiltración de información y la posterior ejecución de comandos destructivos sobre sistemas y datos.
Impacto técnico / operativo	Pérdida total de información y sistemas, interrupción prolongada o definitiva de operaciones críticas
Medida de control recomendada	Implementación de detección temprana de intrusiones, segmentación de red, respaldos offline e inmutables

Reflexión

El análisis de los escenarios mostró que los incidentes de seguridad pueden originarse tanto por ataques externos como por errores internos y fallas operativas, y que todos pueden afectar de manera significativa a los servicios de seguridad de los sistemas. El uso del RFC 4949 y del modelo ITU-T X.800 permitió identificar de forma clara los servicios comprometidos, las amenazas y sus impactos.

Los casos revisados evidencian que la falta de controles básicos, como una adecuada gestión de accesos, configuraciones correctas, respaldos seguros y monitoreo, incrementa el alcance del daño. En el contexto latinoamericano, aplicar estos marcos de referencia resulta útil para mejorar la seguridad de la información con medidas prácticas y realistas.

Bibliografía

Shirey, R. W. (s/f). *RFC 4949: Internet security Glossary, version 2*. IETF Datatracker.

Recuperado el 28 de enero de 2026, de

<https://datatracker.ietf.org/doc/html/rfc4949>

X.800: *Arquitectura de seguridad de la interconexión de sistemas abiertos para*

aplicaciones del CCITT. (s/f). Itu.int. Recuperado el 28 de enero de 2026, de

<https://www.itu.int/rec/t-rec-x.800-199103-i/es>